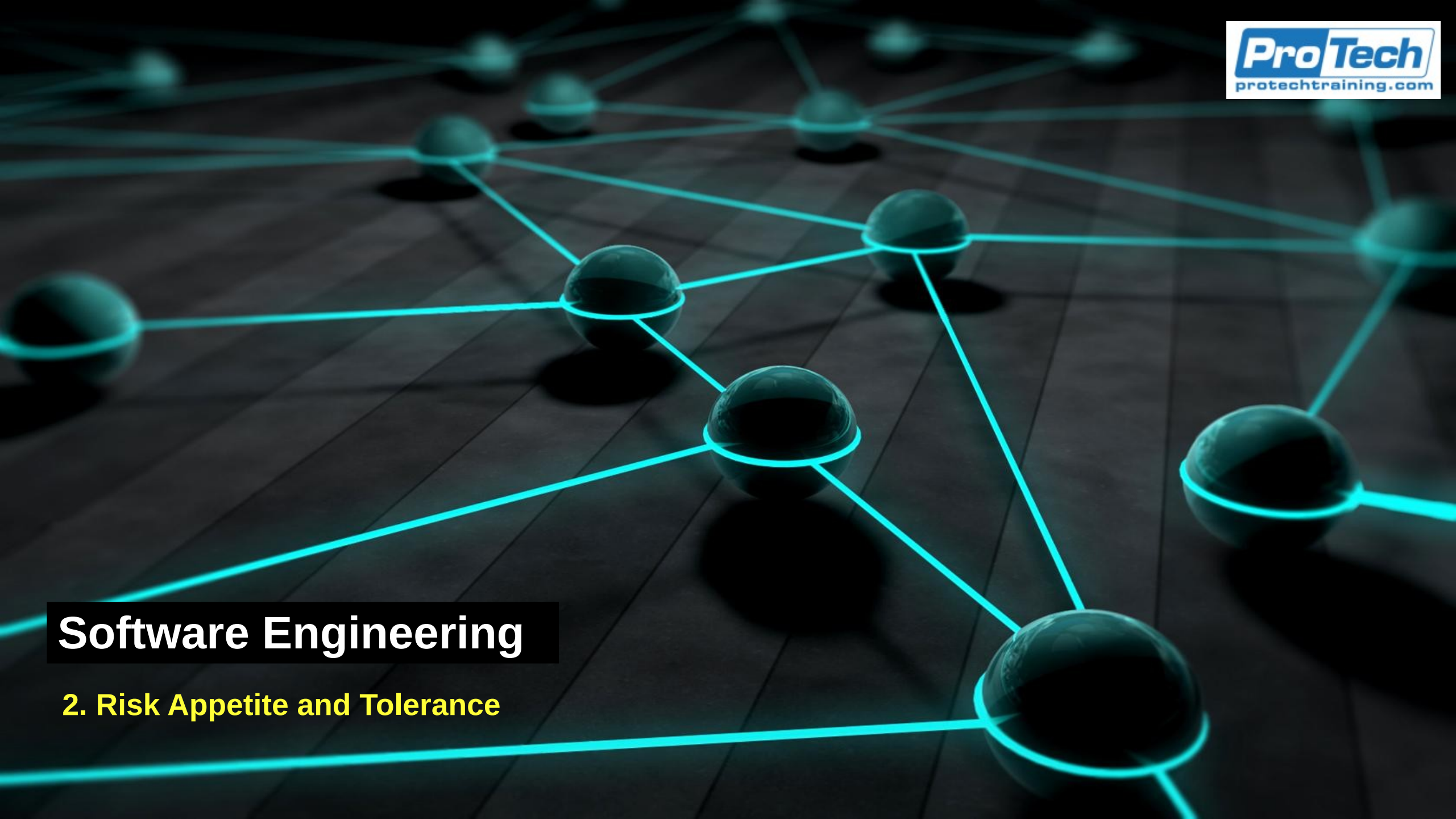




# Software Engineering

## 2. Risk Appetite and Tolerance

# Introduction

- Risk governance
  - While pursuing strategic objectives, organizations have to determine
    - *How much risk the organization is prepared to undertake*
    - *How much risk the organization can absorb and tolerate*
  - Risk governance sets the appropriate level of risk to optimize operations
  - ISACA definitions
    - *Risk Appetite: How much risk the enterprise is willing to undertake*
    - *Risk Tolerance: The acceptable range of risk induced deviation from objectives*
    - *Risk Capacity: The maximum risk related losses the enterprise can bear before its viability is threatened*
    - *Risk Culture: The shared values, norms, and behaviors that shape how people in the organization identify, assess, and respond to risk*
  - Similar concepts exist across risk standards and frameworks
    - *Each standard or framework provides its own formal definition*
    - *The various definitions restate these ideas, tailored to their specific audiences*

# Risk Appetite

- Risk appetite
  - The broad-based amount of risk an entity is willing to accept in pursuit of value
  - For example
    - *“Although the enterprise desires to have no appetite for IT risk, it recognizes that this is impractical in the achievement of its objectives. Therefore, the enterprise will remediate loss scenarios in which aggregate losses of \$1 million or more are at risk.”*
  - Dimension of risk appetite
    - *Objective capacity to absorb loss across multiple asset categories*
    - *For example: capital adequacy, liquidity, reputation, operational assets*
    - *Management’s predisposition to risk: cautious vs. aggressive culture*
    - *Nature of business and risk types: operational, cyber, credit*
    - *Risk appetite can vary across business functions or categories within an organization*
  - Best practices
    - *Risk appetite must be quantified in order to support risk decisions*
    - *Reviewed periodically to reflect changes in the organization and/or business environment*
    - *Integrated into IT governance, investment, and cybersecurity planning*

# Risk Tolerance

- Risk tolerance
  - The acceptable variation in actions relative to objectives that would result from accepting risks
  - Sets “guardrails” to define acceptable levels of risk for specific operations or actions
  - Translates risk appetite into measurable performance indicators such as KPIs or SLA limits
  - Example
    - *“Projects are to be completed within estimated budgets and timeframes, but overruns of 10 percent of budget or 20 percent of time are tolerated.”*
  - Relationship to appetite
    - *Risk appetite = strategic-level willingness to take risk at the enterprise level*
    - *Risk tolerance = operational thresholds of acceptable deviation at the business unit*

# Risk Capacity

- Risk capacity
  - The amount of loss an enterprise can tolerate without risking its continued existence
    - *It represents the upper bound beyond which potential losses due to risk threaten survival of the enterprise*
  - Sustainable scenario
    - *Risk capacity > risk appetite > actual risk*
    - *When actual risk exceeds capacity, resilience and solvency are threatened*
  - Quantitative measurement of operational continuity capability
    - *Defines the ceiling within which appetite and tolerance are set*
    - *Banks often align this with regulatory ratios*

# Risk Culture

- Risk culture
  - The collection of behaviors and values that support open risk discussions and consistent adherence to risk policies
  - A risk-aware culture
    - *Promotes open discussion of risk*
    - *Ensures alignment between policies, appetite, and actual behavior*
    - *Recognizes risk-taking as necessary for innovation, but within managed limits*
  - Key behaviors
    - *Proactive identification: Early escalation of risk indicators*
    - *Ownership and accountability: All staff own risk, it's not just the responsibility of IT or compliance*
    - *Transparent communication: Avoid hidden agendas and blame culture*
    - *Alignment with objectives: KRIs and decisions aligned with enterprise goals*
    - *Learning from negative outcomes: Post-incident reviews that address root causes*

# Risk Culture

- Risk culture
  - Symptoms of poor risk culture
    - *Misalignment between appetite, tolerance, and policy*
    - *Failure to enforce risk policies*
    - *A blame culture that discourages transparency and collaboration*
- Summary
  - Risk capacity = maximum loss the organization can survive (CFO / CRO)
  - Risk appetite = desired level of risk to achieve strategy (board / exec mgmt)
  - Risk tolerance = operational thresholds of tolerated variation (business units)
  - Risk culture = Norms influencing behavior toward risk (everyone)

# Theory vs Reality

- The concepts presented so far are theoretical
  - But the ability to be effective in each of these areas depends on the process maturity of the organization
  - The maturity definition recap below describes the process of becoming risk culture “mature”

| Level                                 | Description                                                           | Keywords                                       |
|---------------------------------------|-----------------------------------------------------------------------|------------------------------------------------|
| 1. Initial (Ad Hoc)                   | Processes are unstructured, reactive, unpredictable.                  | Firefighting, inconsistent, individual heroics |
| 2. Repeatable                         | Basic processes exist and are partially documented; some consistency. | Procedural, partially controlled               |
| 3. Defined                            | Processes are standardized, documented, and communicated.             | Institutionalized, proactive                   |
| 4. Managed (Quantitative)             | Metrics are used to monitor and control risk and performance.         | Data-driven, measured                          |
| 5. Optimized (Continuous Improvement) | Processes are continuously improved using quantitative feedback.      | Predictive, resilient, adaptive                |

# Risk Appetite and Maturity

| Maturity Level | Characteristics of Risk Appetite                                                                                | Capability Impact                                                                   |
|----------------|-----------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| 1 – Initial    | No formal risk appetite statement. Risk decisions made individually or reactively.                              | Organization cannot articulate acceptable risk; exposure is inconsistent.           |
| 2 – Repeatable | Management begins to express appetite qualitatively (“we are risk-averse”).                                     | Risk-taking guided by intuition, not metrics. Strategic alignment limited.          |
| 3 – Defined    | Risk appetite formally approved by board and cascaded through units.                                            | Enables alignment between IT and enterprise strategy. Basic governance established. |
| 4 – Managed    | Appetite quantified (e.g., \$ thresholds, metrics, KRIs). Linked to capital, compliance, and performance data.  | Decisions are consistent, traceable, and auditable. Enables proactive management.   |
| 5 – Optimized  | Appetite dynamically adjusted based on environmental scanning, predictive analytics, and resilience objectives. | Organization uses risk appetite to guide innovation and resilience investments.     |

## Reliability correlation:

At Levels 4–5, systems are designed with *measurable reliability targets* (e.g., RTOs, SLAs) that align with quantified appetite for downtime or service loss.

# Risk Appetite and Maturity

| Maturity Level | Characteristics of Risk Tolerance                                                         | Capability Impact                                                                    |
|----------------|-------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|
| 1 – Initial    | No defined tolerance thresholds. Risk responses vary by individual manager.               | High volatility in outcomes; compliance and reliability are inconsistent.            |
| 2 – Repeatable | Some project-level tolerances defined (e.g., cost/time overruns).                         | Partial control achieved but no enterprise alignment.                                |
| 3 – Defined    | Enterprise-wide risk tolerance limits approved and documented.                            | Enables comparison across units; consistent risk reporting.                          |
| 4 – Managed    | Tolerance integrated with KRIs and KPIs; monitored continuously.                          | Supports data-driven resilience decisions (e.g., automatic triggers for mitigation). |
| 5 – Optimized  | Tolerance dynamically linked to risk analytics, AI/ML forecasting, and scenario modeling. | Enables adaptive resilience; organization balances risk and opportunity optimally.   |

## Reliability correlation:

At higher maturity, **risk tolerance thresholds align with reliability objectives** — e.g., “system uptime must not fall below 99.95%” becomes both a tolerance and a reliability metric.

# Risk Appetite and Maturity

| Maturity Level | Characteristics of Risk Capacity                                                                       | Capability Impact                                                                          |
|----------------|--------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| 1 – Initial    | No clear understanding of maximum risk exposure or loss absorption.                                    | Financial or operational shocks can threaten survival.                                     |
| 2 – Repeatable | Some awareness of limits (e.g., budget, compliance penalties).                                         | Risk capacity treated as static; no link to resilience or capital planning.                |
| 3 – Defined    | Capacity quantified based on financial, technical, and human resources.                                | Enables setting realistic risk appetite boundaries.                                        |
| 4 – Managed    | Capacity dynamically assessed (e.g., stress testing, scenario planning).                               | Organization can plan resilience capacity (redundancy, liquidity buffers).                 |
| 5 – Optimized  | Real-time monitoring of operational capacity; integration with resilience indicators (MAO, RTO, MTBF). | Organization operates within its adaptive capacity, ensuring continuity even under duress. |

## Reliability correlation:

At Level 5, **risk capacity = resilience capacity** — the ability to sustain operations under stress without exceeding failure thresholds.

# Risk Culture and Maturity

| Maturity Level | Characteristics of Risk Culture                                                                                 | Capability Impact                                                                                 |
|----------------|-----------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| 1 – Initial    | Reactive, blame-oriented culture. Risk seen as failure.                                                         | Employees hide incidents; low transparency; weak learning from failure.                           |
| 2 – Repeatable | Some risk awareness, but accountability unclear.                                                                | Limited risk communication; siloed IT and business teams.                                         |
| 3 – Defined    | Leadership communicates risk values; roles and responsibilities clear.                                          | Collaboration and learning begin; early resilience mindset forms.                                 |
| 4 – Managed    | Risk culture measured through surveys, training, and behavioral indicators.                                     | Risk-taking becomes calculated; culture supports adaptive response.                               |
| 5 – Optimized  | Culture of continuous learning and cross-functional trust. Risk and resilience are embedded in decision-making. | Organization achieves <i>resilience by design</i> — every level anticipates and adapts to change. |

## Reliability correlation:

A mature risk culture ensures reliability through **shared accountability, transparent reporting, and a learning orientation**, which reduces recurrence of incidents and accelerates recovery.

# Maturity vs. Resilience Capability

| Maturity Level | Risk Governance State                                 | Resilience Capability                                                       |
|----------------|-------------------------------------------------------|-----------------------------------------------------------------------------|
| 1 – Initial    | Reactive, fragmented; no defined appetite or culture. | Fragile — dependent on individual heroics.                                  |
| 2 – Repeatable | Some processes; partial alignment.                    | Recoverable but inconsistent.                                               |
| 3 – Defined    | Policies institutionalized; shared understanding.     | Sustainable resilience achievable with structured BCP.                      |
| 4 – Managed    | Quantitative control, predictive monitoring.          | Measurable reliability; proactive continuity management.                    |
| 5 – Optimized  | Integrated, adaptive, and learning organization.      | Resilient-by-design; reliability engineered into business processes and IT. |

# Maturity Implications

- Maturity drives control
  - Without process maturity, risk frameworks remain theoretical
- Quantification enables resilience
  - Risk appetite and tolerance translate into measurable reliability and resilience goals
- Culture amplifies capability
  - A mature risk culture transforms risk awareness into resilient behavior
- Risk capacity defines operational limits
  - Resilience planning begins by understanding the true risk capacity of critical functions
- Integration is the goal
  - Risk and reliability management converge under a unified resilience framework

# Risk Culture

- The result of combination of external and internal factors
- External or environmental
  - Sets boundaries, incentives, pressures, and references for “acceptable” risk behavior
    - *Regulatory environment*
    - *Legal and compliance pressures*
    - *Industry norms and peer benchmarking*
    - *External stakeholder expectations*
    - *Macro geopolitical environment*
    - *National culture and societal norms*

# Risk Culture

- Internal or organizational
  - Shape day-to-day behaviors, decision processes, risk escalation, and collective mindsets
    - *Leadership behavior and tone from the top*
    - *Incentives, performance measurement and rewards*
    - *Governance structure and oversight*
    - *Communication and information flows*
    - *Subcultures and functional silos*
    - *Historical incidents and “lessons learned”*
    - *HR practices: hiring, onboarding, training*
    - *Formal systems and control architecture*

# Risk External Culture

- Regulatory
  - Supervisory regime and enforcement intensity
    - Banking and financial services regulators often impose culture and conduct expectations as part of regulatory guidance or exams
    - *For example “culture of compliance” and “risk culture expectations”*
  - Threat of regulatory penalties, fines, or reputational sanctions motivates organizations to embed risk culture more robustly
  - In environments with weak enforcement, organizations may pay lip service to “risk culture” while focusing compliance efforts on ticking boxes
  - Example
    - *A bank subject to regular regulatory audits may emphasize rigorous risk escalation and whistleblower frameworks*
    - *A non-regulated technology firm might have more latitude to undertake risk without triggering external attention or investigations*

# Risk External Culture

- Industry norms
  - Peer benchmarking and competitive pressures
    - *Peer benchmarking: comparing an organization's performance, processes, or risk posture against similar organizations*
  - Industries with high reputational risk have peer expectations that create norms
    - *High reputation risk example, banking, insurance, pharmaceuticals, energy*
    - *Fore example: "Every major bank must have a 'first-line, second-line, third-line' risk culture."*
  - Benchmarking reports create aspirational pressure
    - *For example: "Top-tier banks have X maturity level in risk culture"*
  - If competitors tolerate more risk or cut corners
    - *Can either erode culture by triggering a "race to the bottom"*
    - *Or provoke stronger counter-measures to differentiate on trust*

# Peer Benchmarking

- Peer benchmarking
  - Measuring the organization against comparable institutions
    - *For example, banks compare their incident response times, cybersecurity controls, recovery objectives, or capital/risk exposure to other banks of similar size and complexity*
  - Identifying gaps and leading practices
    - *If peers have stronger resilience testing, stricter third-party oversight, or faster notification capabilities, regulators may expect the organization to close the gap*
  - Providing evidence to regulators and auditors
    - *Benchmarks help show that the organization's risk posture is not only internally acceptable but also aligned with industry norms and supervisory expectations*
  - Supporting KRIs, governance, and strategic decisions
    - *Metrics like RTOs, vendor performance, staffing levels, or breach frequency are benchmarked to evaluate whether the organization's targets and thresholds are realistic and defensible*

# Peer Benchmarking

- Goals of peer benchmarking
  - To ensure firms don't fall significantly behind industry norms
  - To encourage consistent practices across institutions
  - To identify systemic weaknesses across a sector
  - To justify improvements, resources, or investments in controls

# External Risk Culture

- Legal
  - Occurs in jurisdictions with strict liability, class-action exposure, or heavy litigation
  - Organizations may become excessively risk-averse and suppress open discussion of near misses
  - In environments with weak liability, there is less external pressure to report or escalate issues
- Macro-economic
  - Volatility in the economy forces more frequent, severe stress events
    - *For example: volatility in financial markets, cyber threat landscape or geopolitical risk*
    - *Organizations in volatile environments often develop “risk hardiness” or more conservative cultures*
    - *More stable environments might breed complacency, overconfidence, or “it won’t happen to us” attitudes*

# External Risk Culture

- Societal culture
  - Differences in national culture shape
    - *How people interpret authority*
    - *Whether they feel safe reporting bad news*
    - *Whether questioning the chain of command is acceptable, etc.*
  - An empirical study found that national culture, industry type, and organizational security culture significantly influence individuals' security behavior

# Internal Risk Culture

- Tone from the top
  - Leadership actions speak louder than policies
    - *If senior executives bypass controls, dominate decisions without discussion, or penalize risk disclosure, they undermine culture*
    - *When the board or CEO publicly demands risk transparency, participates in discussions, and visibly supports risk escalation, that sets a cultural anchor*
  - In studies of ERM sophistication, organizations where leaders push for stronger oversight show higher maturity in risk culture

# Internal Risk Culture

- Incentives
  - Misaligned incentives generate cultural tension between actions mitigating risk
    - *For example: rewarding revenue growth without penalizing risk overruns*
  - Risk management failure arises when short-term individual incentives conflict with long-term enterprise risk appetite.
  - If risk controllers or compliance units are not part of performance evaluations, their voice may be sidelined

# Internal Risk Culture

- Governance structure
  - Where risk governance is weak culture is less capable of intervening
    - *For example: Risk committees that never challenge or risk functions under powered*
  - Clear accountability lines and escalation paths matter: who owns risk, who can override, who judges exceptions
  - Frequency and seriousness of oversight affect how risk culture stays alive day to day

# Internal Risk Culture

- Information flow
  - A “speak-up” environment where there are channels for escalation, anomaly reporting, whistleblowing
  - If information is hoarded in silos or filtered upward aggressively, senior leadership gets distorted views
  - Informal networks, like power centers and shadow communication channels, can override formal governance.
    - *McKinsey notes that informal networks often influence how formal risk channels operate in practice*

# Internal Risk Culture

- Functional silos
  - Large organizations often have multiple micro-cultures
    - *For example: development, operations, risk, audit*
  - These different micro-cultures may have varying attitudes to risk
  - This can create subculture conflict
    - *For example: DevOps striving for rapid release conflicts with security requiring cautious rollout*
- Historical memory
  - Past failures, “near misses,” or regulatory fines leave cultural legacies
    - *Either fear-based suppression or learning orientation based on transparent root cause reviews*
  - Organizations that do after-action reviews, “lessons learned” loops, and close the loop by changing practices build a stronger risk culture over time

# Internal Risk Culture

- Control systems
  - The architecture of controls, systems, metrics, dashboards, and analytics reinforce or weaken culture
  - If control systems are opaque, overburdensome, or disconnected from decision-making, they may generate bypassing or cynicism
  - The strength of risk measurement, like KRIs and predictive analytics, can influence how visible risks are, and how credible the risk function is

# Appetite vs. Tolerance

- Risk Appetite
  - Strategic-level statement of how much risk and of what types an organization is willing to accept in pursuit of its objectives
    - *Forward-looking, aspirational, and reflects the risk culture*
- Risk Tolerance
  - Translates risk appetite into operational thresholds or boundaries of acceptable deviation
  - Quantifies appetite within a framework of real world constraints

# Risk Tolerance

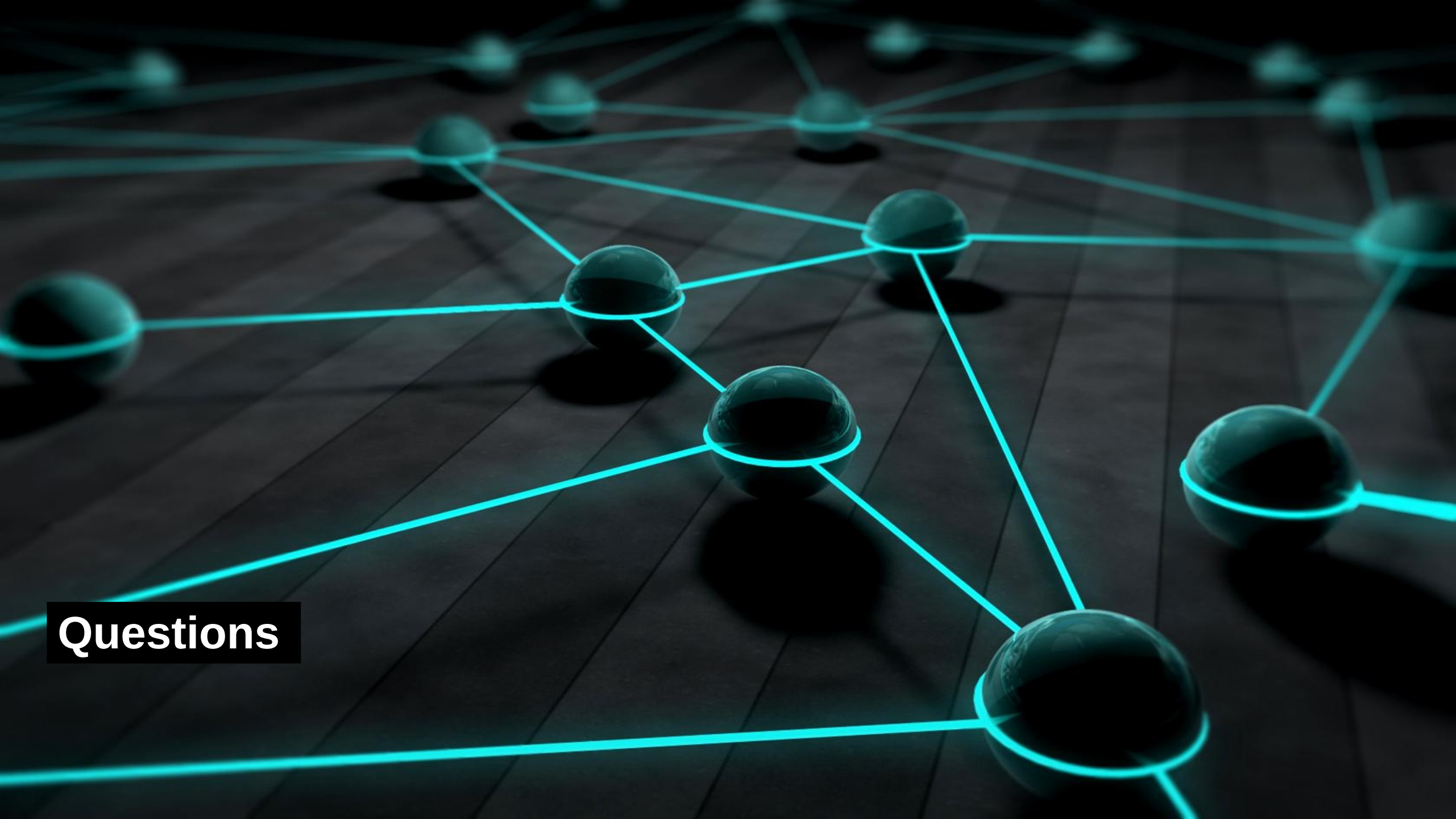
- Tolerance is often expressed in dual limits
  - Minimum and maximum, or multi-dimensional thresholds like financial, time and severity dimensions
    - *Minimum limits prevent total risk avoidance policies and behaviors*
- Tolerances must be reviewed and recalibrated periodically
  - As systems evolve and threat profiles shift, tolerances that were once acceptable may become dangerous
- Measurement or monitoring may be immature
  - Organizations may define coarse tolerances like low/medium/high bands rather than quantified numerical thresholds

# Risk Trade-Offs

- Appetite vs capacity constraints
  - No matter how ambitious appetite is, it must not exceed capacity or the organization becomes in danger of insolvency or collapse
- Tolerance cost vs benefit
  - Tightening tolerance with smaller deviations often increases control and remediation costs
- Strategic ambition vs regulatory constraints
  - Appetite to innovate might push for looser tolerance
  - But regulators or standards may force stricter tolerance in certain domains, like data privacy
- Measurement maturity vs precision of tolerance
  - Immature measurement capabilities force broader tolerances that may allow more risk
- Culture and behavior vs tolerance enforcement
  - If the culture routinely grants exceptions or ignores breaches, tolerance has little real effect

# Uncertainty

- The amount of unavoidable variance in future predictions of external factors
  - Essentially, the risk of not being able to predict the future with certainty
    - *For example: The impact of AI on the economy and banking*
    - *For example: Inconsistent or changing positions on major regulatory issues*
- Uncertainty options
  - Commit to one possible outcome
    - *High level of risk but potentially high level of returns*
  - Spread the risk
    - *Make investments in the different alternatives, hedging bets*
  - Ignore the uncertainty
    - *Assume the status quo will continue, often the worst possible choice*



**Questions**